

UNIVERSITY OF BIRMINGHAM

School of Computer Science

06 34240

Secure Software and Hardware Systems

Main Summer Examinations 2022

Secure Software and Hardware Systems

Note: Answer ALL questions. The paper will be marked out of 60, which will be rescaled to a mark out of 100.

Question 1

- (a) Give an example of some pseudo-code that contains an out-of-bounds write.
[2 marks]
- (b) How might a programmer prevent an out-of-bounds write appearing in her code?
[2 marks]
- (c) The code below has mistakes. Highlight any two and explain them.
[8 marks]
- (d) Write pseudo-code to fix the two mistakes you noted.
[8 marks]

```
1  #define MAX_ARRAY_SIZE 5
2  int main() {
3      uint8_t* my_array; // 8 bit integers
4      srand(time(0));    // Seed the random number
5
6      // Make the space
7      my_array=malloc(sizeof(uint8_t)*MAX_ARRAY_SIZE);
8      if (my_array==NULL) {
9          fprintf(stderr," Malloc failed.\n");
10     }
11
12     // Populate the array.
13     for (int i=0;i<=MAX_ARRAY_SIZE;i++) {
14         // Generate a random number between 0-999
15         my_array[i] = rand() % 1000;
16     }
17
18     printf("How many do you want to print?\n");
19     int user_input;
20     scanf("%i", &user_input);
21
22     // Print the array
23     for (int i=0;i<user_input;i++) {
24         printf(" Array[%i] contains: %i \n",i,my_array[i]);
25     }
26     free(my_array);
27 }
28 }
```

Question 2

You are given the task of validating the security of a web service. Although it is not possible to prove that it contains no bugs, you want to be as sure as possible that the service does not contain memory-related exploits. You do not have source code.

- (a) If you are only able to access the service over a network, making the same connections that an ordinary user would make, what approaches can you take to confirm the web application handles memory correctly? Explain why you are limited in your choices, the sort of tools might you use, and how confident would you be in the results.

[10 marks]

- (b) If additionally you have access to the platform upon which the service is running, what additional investigations could you make? Again, explain the limitations, tooling and confidence you will have.

[10 marks]

Question 3

The following code snippet is part of a bitsliced implementation of PRESENT on the Raspberry Pi Pico to XOR a key into the state:

```
// uint32_t state_bs[64] holds the bitsliced state
// uint32_t key_bits[64] contains the round key:
// each elements holds one bit i.e. is 0 or 1

for(uint8_t i = 0; i < 64; i++) {
    // XOR the key into the state
    if(key_bits[i])
        states_bs[i] ^= 0xffffffff;
}
```

- (a) Assume that you can measure the runtime of the complete for loop in the above code. Which information does this leak on the contents of `key_bits`? Is this a substantial security problem, assuming a random key? **[4 marks]**
- (b) Now, assume that you can use simple power analysis to measure the runtime of each loop iteration *i individually*. Describe how this can be used to recover the full contents of `key_bits`. **[6 marks]**
- (c) Re-write the above code snippet so that it runs in constant time, independent of the values in `key_bits`. For that, replace the `if` with Boolean operator(s). Make use of the fact that `-0 = 0` and `-1 = FFFFFFFF` on a 32-bit architecture. Explain briefly why your modified version is correct and constant-time. **[7 marks]**
- (d) Now we look at performance: an implementation of a single AES encryption (i.e. of 128 bit of plaintext) takes 27765 clock cycles on the Pi Pico. The bitsliced PRESENT implementation takes 129024 cycles to encrypt 32 blocks of 64-bit PRESENT plaintext. Compute the cycles per bit for both implementations. Which one is faster? **[3 marks]**